ПРИНЦИПИ БУДОВИ ВІРТУАЛЬНИХ ЗАХИЩЕНИХ МЕРЕЖ

(Virtual Private Network, VPN)

1 Технології VPN

1.1 Види віртуальных захищених мереж

- GRE тунелі
- MPLS VPN
- VPN на базі PPP (PPP over SSH, PPP over SSL/TLS, PPPoE, PPTP)
- IPSec VPN
- Web VPN (SSL VPN) – захищений доступ до web – сайтів

- Тунель між двома точками мережі
- Альтернатива виділеному каналу (захищений канал по незахищеній мережі)
- *Може* забезпечувати захист даних (VPN не є шифруванням)

- захищені
- «провайдерські»

Термін Віртуальний означає, що технології VPN створюють накладні мережі, що працюють поверх існуючих фізичних мереж.
Визначальною ознакою існування VPN можна вважати створенння деякого логічного каналу з адресацією та наявність віртуальних інтерфейсів (таких, що не віповідають жодному фізичному мережному адаптеру). Приватність може означати не тільки захист, а також мережі, що створюються для приватного користування. Як приклад, технологія MPLS дозволяє співіснувати багатьом віртуальним мережам різних клієнтів ISP в єдиній фізичній мережі, причому діапазони адрес в мережах клієнтів можуть повторюватись (наприклад, це можуть бути приватні адреси). Таким чином, технологія MPLS створює віртуальне уявлення, ніби кожний клієнт працює у своїй власній приватній мережі. В цьому контексті VPN були більш ефективним аналогом виділених ліній.

Тобто, технологій VPN що призначені власне для віртуалізації мережної інфраструктури будемо називати “провайдерські VPN”.

З вказаних вище технологій найбільш проста — GRE тунелі, що призначена лише для створення віртуальних тунелів і яка не має аніяких механізмів захисту. Проте це не означає, що разом з GRE тунелями не може використовуватись деяка технологія криптографічного захисту, утворюючи разом повнофункціональну VPN.

З протележного боку складності — провайдерська технологія MPLS (це не протокол, а набір протоколів, які разом дозволяють виконувати багато задач створення віртуальних мереж (накладних, таких що працюють поверх інших). MPLS теж не мають власних механізмів криптографічного захисту, що аніяк не зменшує можливість застосування такого.

Ще слід сказати, що так звані Web VPN (SSL VPN) хоча і мають механізми криптографічного захисту даних, проте не мають власного механізму віртуалізації. Але, знов таки, існує можливість їх використання разом з іншими технологіями віртуалізації мереж, утворюючи разом “справжню” VPN.

- Внутрішні (Intranet VPN) — в межах
- Зовнішні (Extranet VPN) — з”єднання двох сегментів однієї мережі через третю мережу
- Віддаленого доступу (Remote Access VPN) - для мобільного підключення віддалених клієнтів

- Канального рівня (**PPTP, L2F, L2TP**)
- Мережного рівня (**IP Security**)
- Сеансового рівня (**SSL/TLS, HTTPs**)

VPN канального та мережного рівня створюють віртуальне з’єднання так, ніби хости мають безпосереднє підключення, відповідно, на канальному та мережному рівні (та відповідні адресовані інтерфейси).
VPN сеансового рівня, самі по собі, віртуальні мережі (та відповідні інтерфейси) не створюють, тому не можуть вважатись VPN в повному сенсі цього поняття.

- Між кінцевими хостами (хост-хост, End-to-End)
- Між граничними пристроями мереж, шлюзами (мережа-мережа, Edge-to-Edge)
- Між кінцевим хостом та шлюзом мережі або сервером віддаленого доступу (хост-мережа, End-to-Edge)

1.2 Послуги віртуальних захищених мереж

- Автентифікація сторін з'єднання (відправника пакета)
- Конфіденційність (шифрування)
- Достовірність та цілісність (HMAC автентифікація пакетів)
- Неможливість відмови факту відправлення/отримання даних
- Захист від повторного використання даних
- Керування ключами

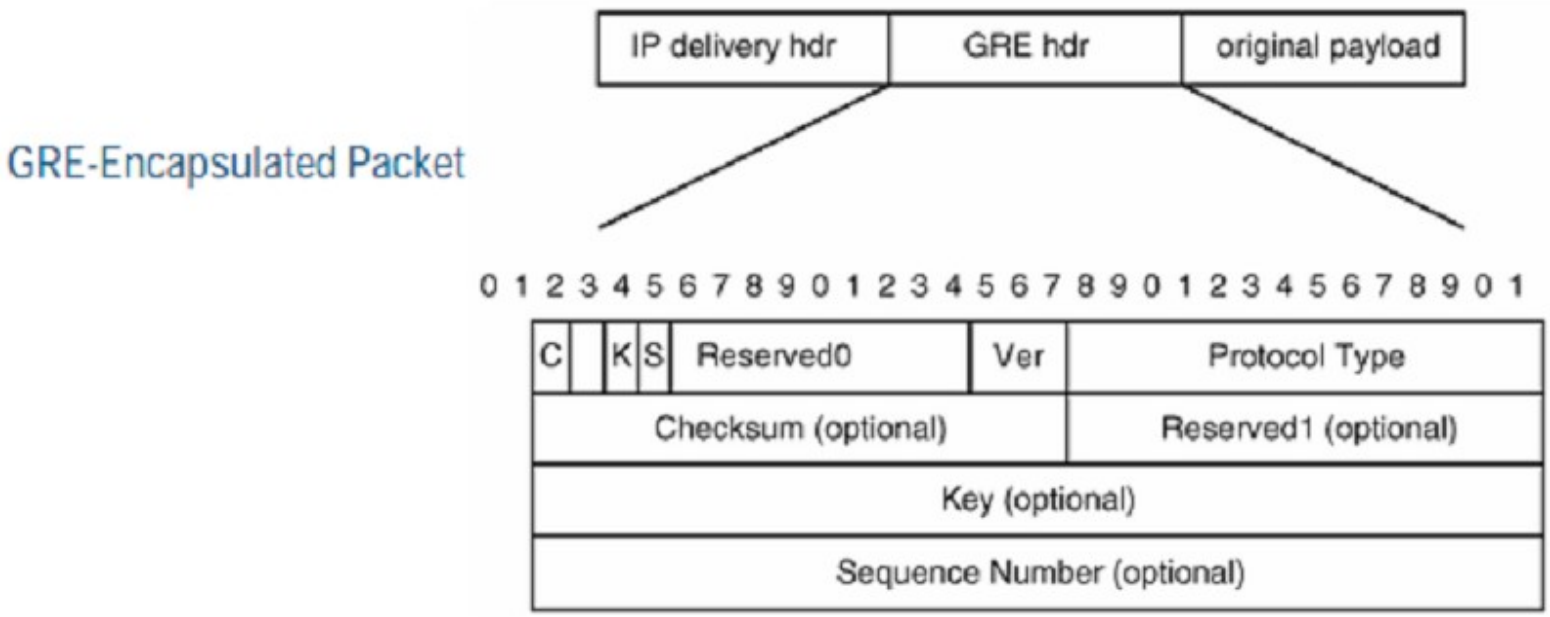
1.3 Пристрої VPN

- програмний клієнт
- маршрутизатор
- мережний екран (шлюз)

1.4 Тунелювання мережного трафіка

Протокол інкапсуляції GRE (Generic Routing Incapsulation, RFC 2784, 2890, Protocol #47)

Інкапсуляція пакета на мережному рівні з новим IP-заголовком



Протокол GRE створює віртуальний тунель між двома віддаленими IP адресами та передає між ними пакети, інкапсулюючи їх зі своїм заголовком. На мережному рівні віртуальний тунель працює так, ніби два кінця тунелю знаходяться на відстані одного хопа (можливо перевірити ч-з traceroute).
Альтернатива GRE: IPinIP (RFC 1853, 2003)

1.5 Віртуальні захищені мережі канального рівня

Протокол PPTP (TCP, 1723 порт) – еволюція протокола PPP (імітація знаходження у віддаленій LAN на мережному рівні).

- Тунелювання PPP трафіка через IP мережу
- PPTP не визначає методи автентифікації та шифрування
- PPP визначає механізм узгодження алгоритмів автентифікації, шифрування тощо

Автентифікація: PAP, CHAP, MS-CHAP (одночасно DES и MD4), MS-CHAPv2 (MD5)
Шифрування: MPPE (Microsoft Point-to-Point Encryption) 40/128 bit key

<table>
<tr><td rowspan="2">PPP compressed data</td><td rowspan="2">LCP, CHAP, IPCP</td><td>TCP/UDP</td></tr>
<tr><td>IP</td></tr>
<tr><td colspan="3">PPP</td></tr>
<tr><td colspan="3">GRE</td></tr>
<tr><td colspan="3">IP</td></tr>
</table>

*****Дана схема, окрім стеку протоколів, які використовує PPTP, також показує послідовність заголовків, які має PPTP пакет в тому чи іншому режимі роботи.

Протокол L2F – тунелювання багатьох мережних протоколів (не тільки IP)

Протокол L2TP – протокол тунелювання на основі PPTP та L2F

2 Протоколи IP Security

2.1 Архітектура протоколів IP Security (RFC 4301)

IKE – Internet Key Exchange (UDP, port 500, RFC 7296 IKEv2): керуючий протокол, узгодження параметрів захисту, взаємнох автентифікації сторін и встановлення захищеного сеансу, автоматичної генерації та оновлення ключа

ESP – (Protocol # 50, RFC 4303): протокол захищеної інкапсуляції (автентифікації даних, забезпечення цілісності та шифрування)

AH – (Protocol # 51, RFC 4302): протокол автентифікації даних та забезпечення цілісності

*Для IPv6 IPSecurity працює аналогічно, проте вже є частиною стандартів IPv6.

<table>
<tr><td rowspan="2">ISAKMP</td><td colspan="2">IP, TCP, UDP</td><td rowspan="2">IP, TCP, UDP</td></tr>
<tr><td rowspan="2">ESP</td><td>ESP</td></tr>
<tr><td>UDP</td><td>AH</td><td>AH</td></tr>
<tr><td colspan="4">IP</td></tr>
</table>

Криптографічні перетворення та протоколи в архітектурі IP Security

Шифрування: DES (56 bit key / 64 bit), 3DES (168 bit key / 64 bit), AES (128, 192, 256), SEAL

Геш-функії (HMAC – Heshed Message Authentication Code, RFC 2104): MD5 (128 bit), SHA-1 (160bit) (автентифікація відправника та повідомлень, цілісність повідомлень)

Цифровий підпис: RSA

Генерація ключа: Diffy- Hellman

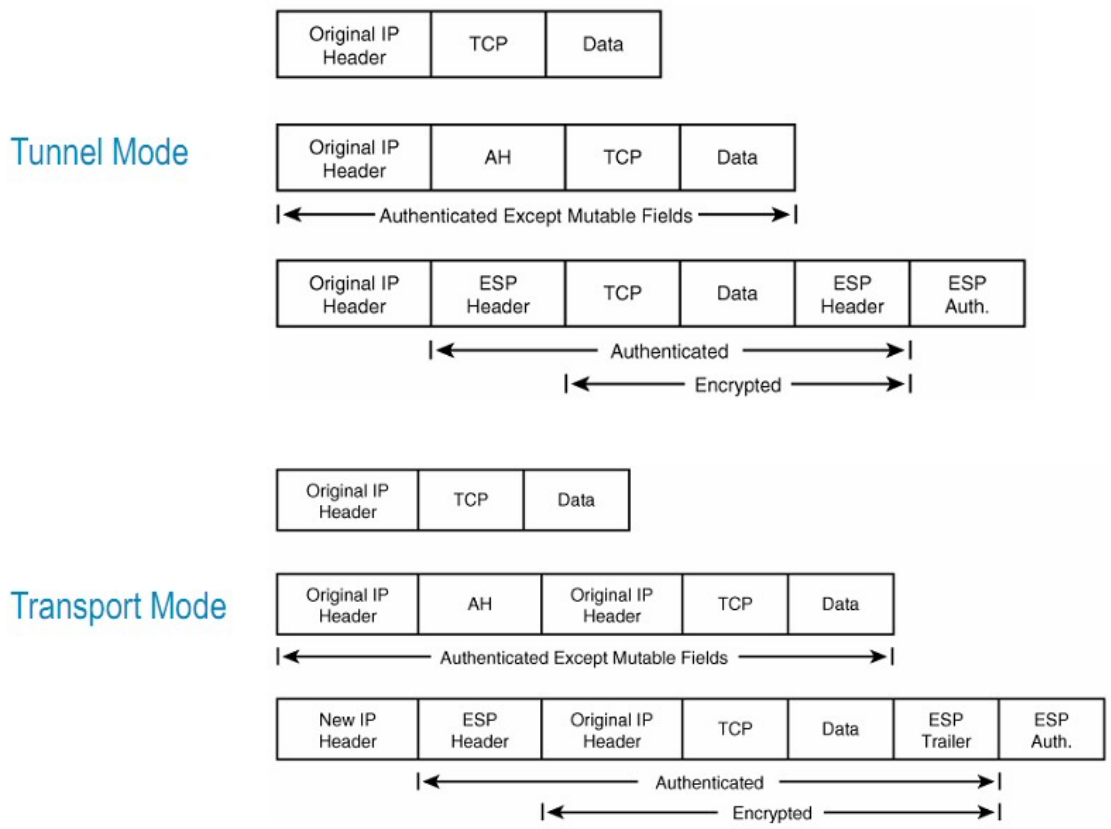
Інфраструктура відкритих ключів (PKI): X.509

Автентифікація IPSec: PSK (поділюваний ключ), RSA-signature, Сертификат, Kerberos (Win)

Криптоперетворення за замовчуванням:

- aes-cbc-128 3des
- sha md5
- group 5 2

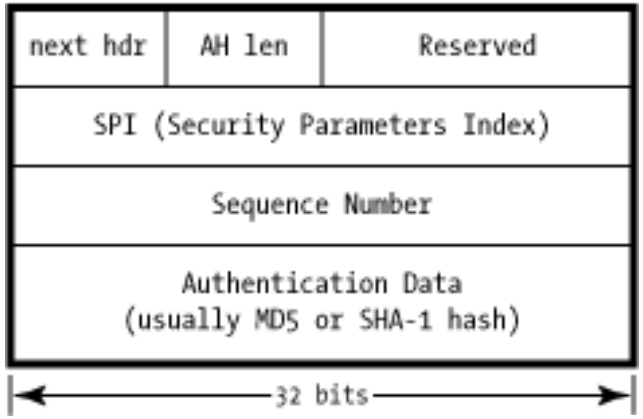
2.2 Режими роботи IPSec VPN

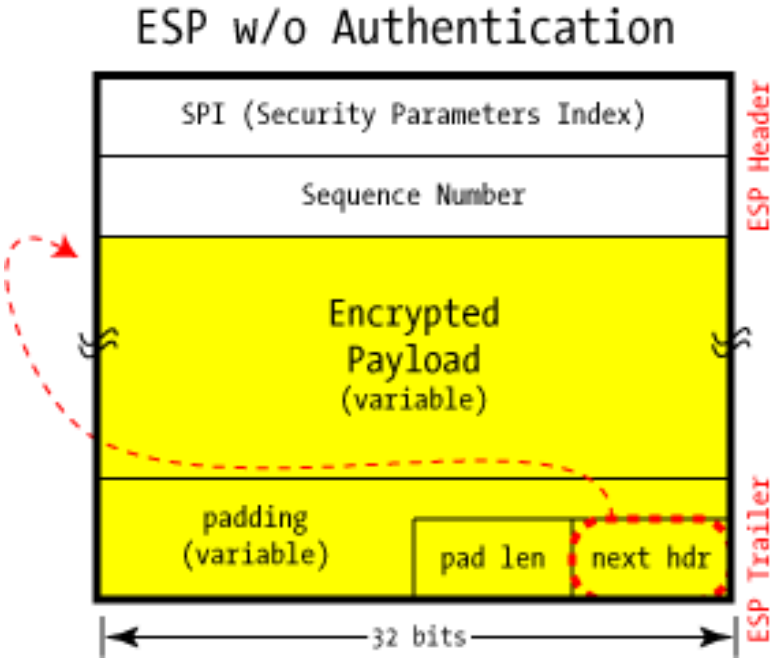


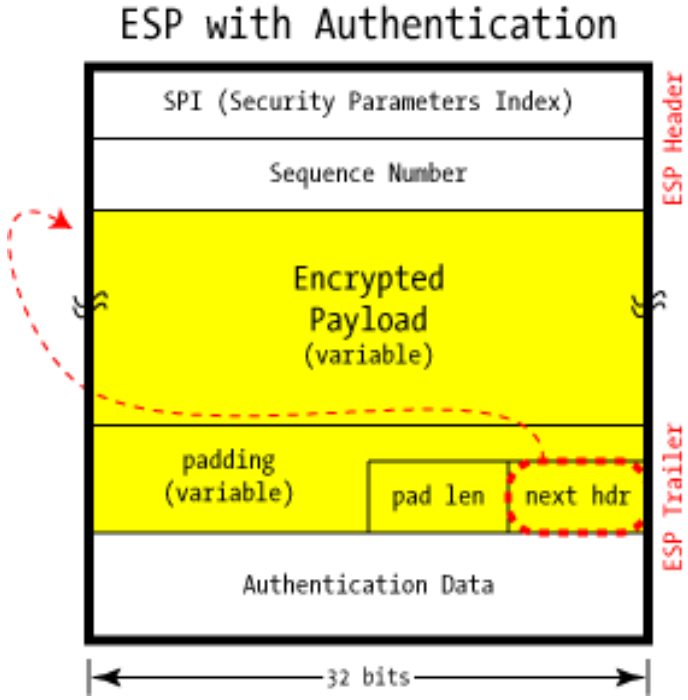
Транспортний режим – захист тільки вмісту пакетів (payload), заголовки не змінюються (кінцева адреса тунелю - адреса отримувача)

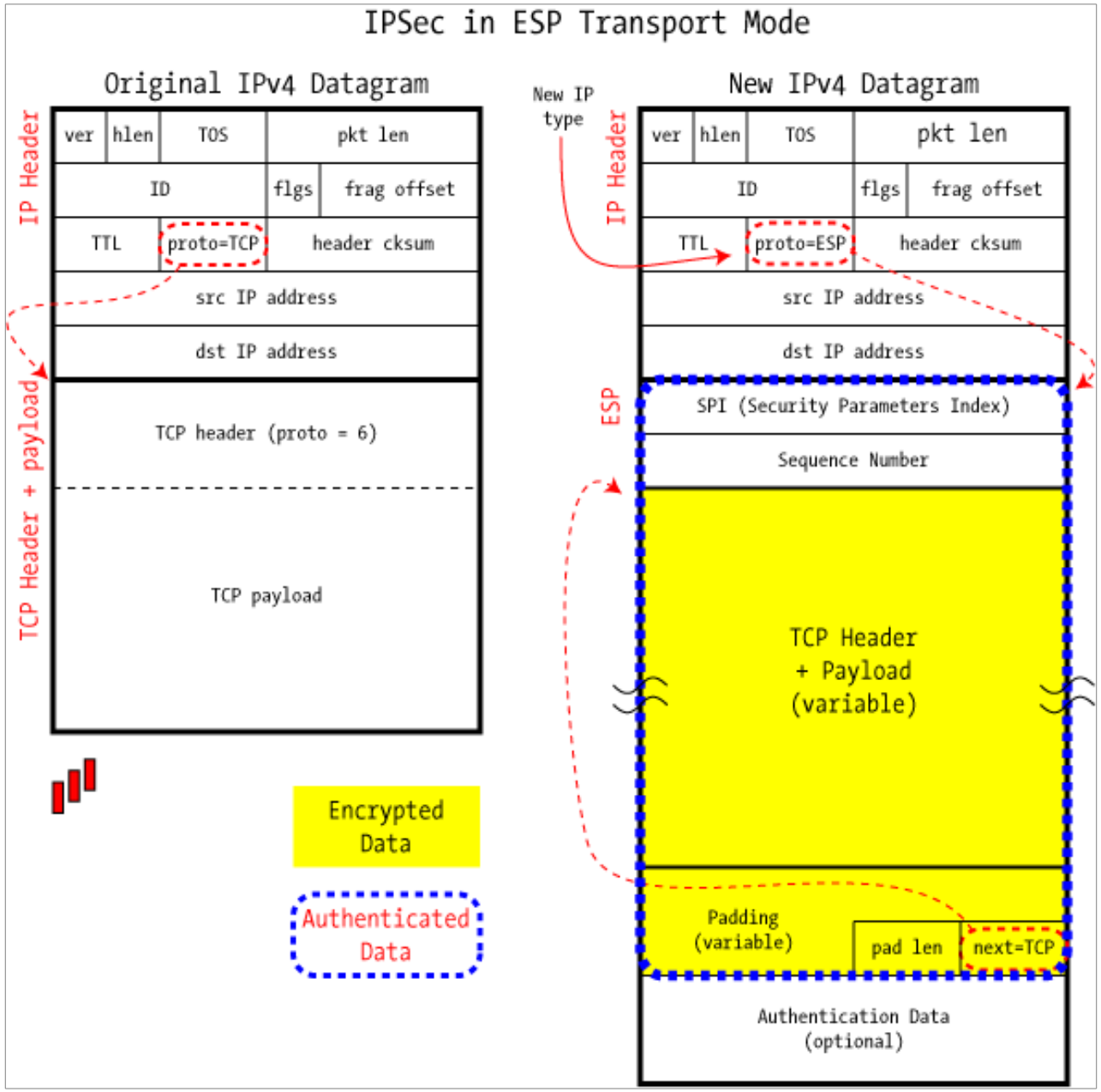
Тунельний – пакет автентифікується/шифрується повністю та додається новий заголовок (з”єднання між шлюзами мереж)

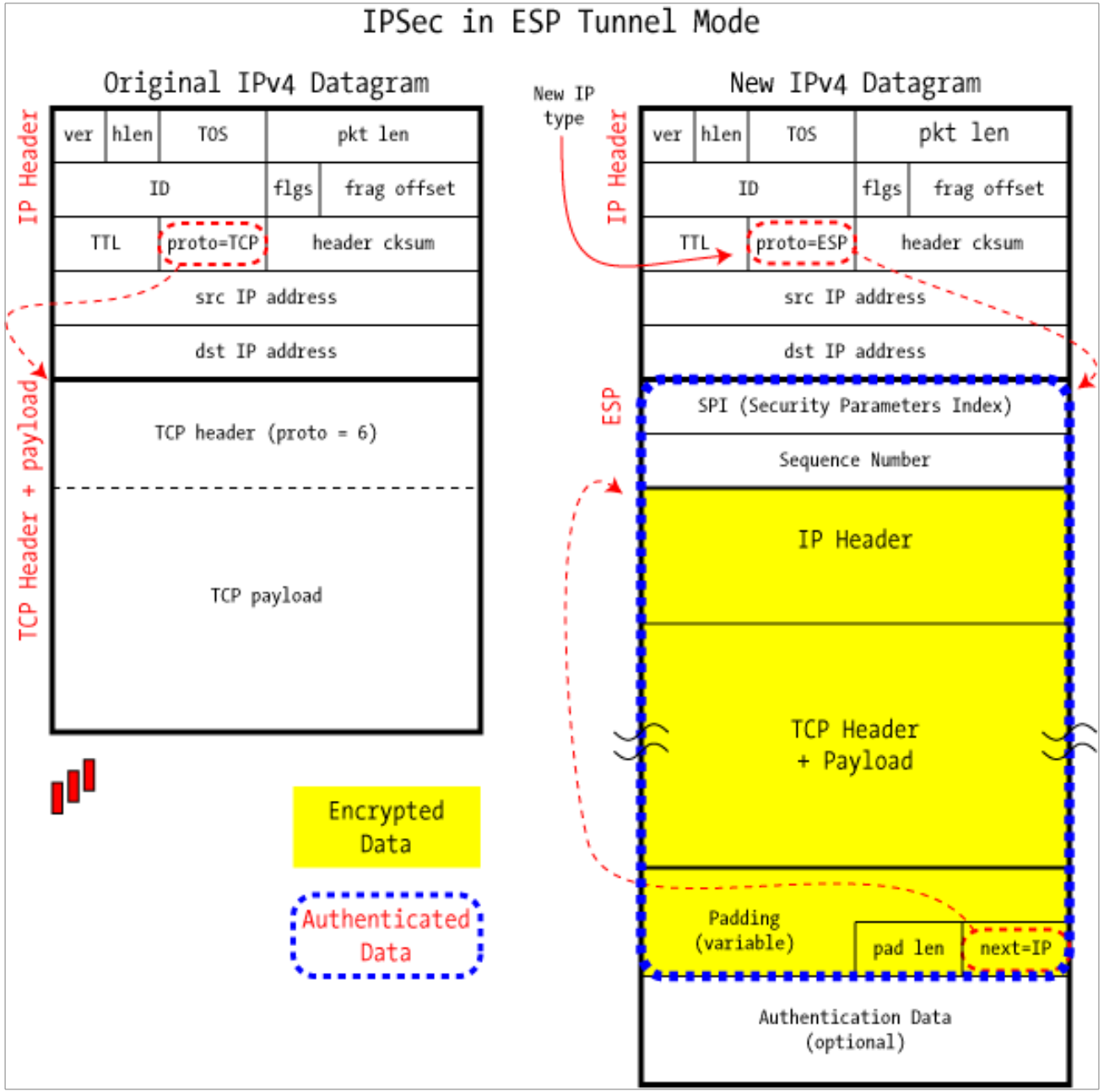
2.3 Формати пакетів

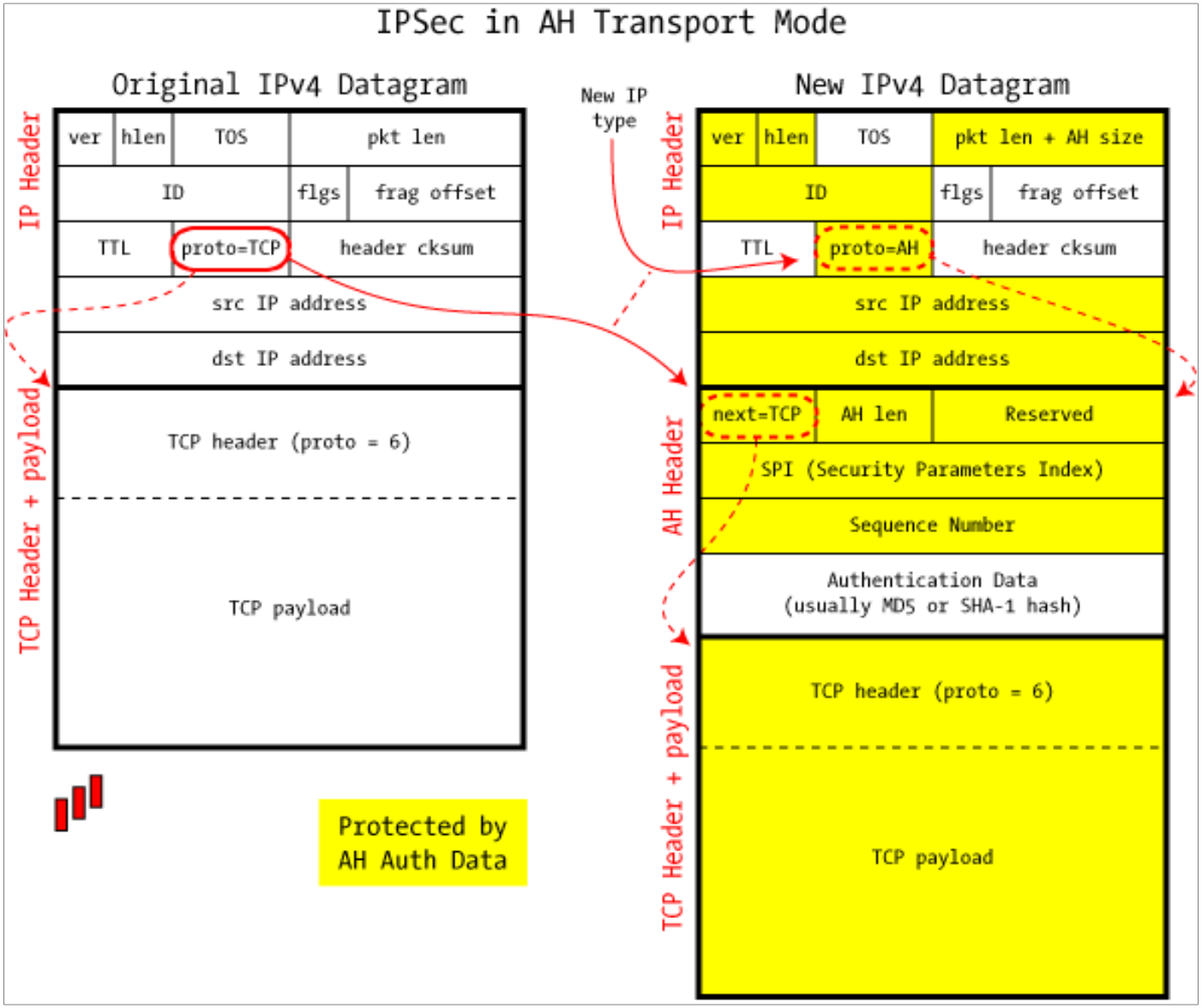


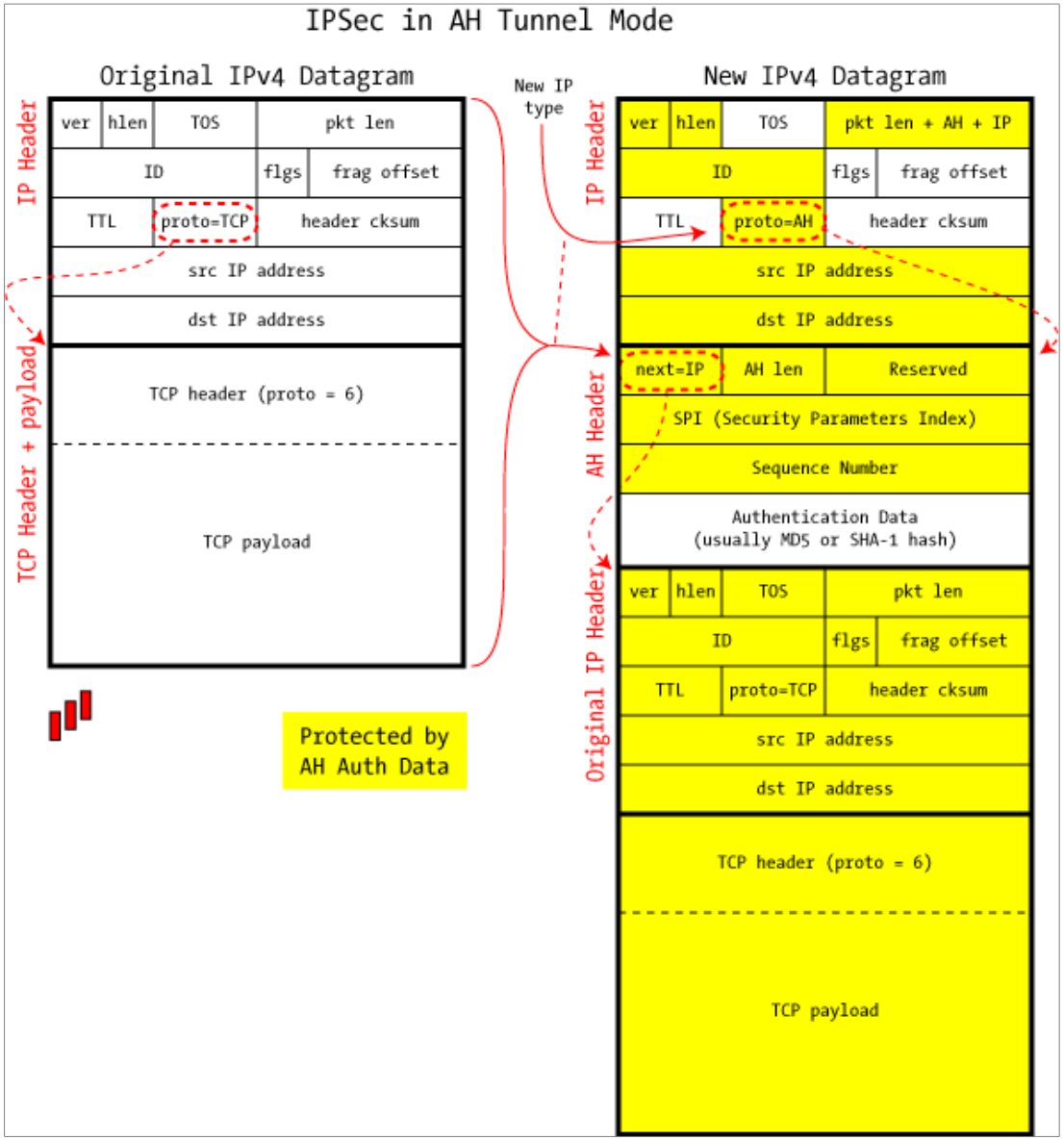





IPSec in ESP Transport Mode
Original IPv4 Datagram
IP Header
ver
hlen
TOS
pkt len
ID
flgs
frag offset
TTL
proto=TCP
header cksum
src IP address
dst IP address
TCP Header + payload
TCP header (proto = 6)
TCP payload
New IP type
New IPv4 Datagram
IP Header
ver
hlen
TOS
pkt len
ID
flgs
frag offset
TTL
proto=ESP
header cksum
src IP address
dst IP address
ESP
SPI (Security Parameters Index)
Sequence Number
TCP Header
+ Payload
(variable)
Padding
(variable)
pad len
next=TCP
Authentication Data
(optional)
Encrypted
Data
Authenticated
Data


IPSec in ESP Tunnel Mode
Original IPv4 Datagram
IP Header
ver
hlen
TOS
pkt len
ID
flgs
frag offset
TTL
proto=TCP
header cksum
src IP address
dst IP address
TCP Header + payload
TCP header (proto = 6)
TCP payload
New IP type
New IPv4 Datagram
IP Header
ver
hlen
TOS
pkt len
ID
flgs
frag offset
TTL
proto=ESP
header cksum
src IP address
dst IP address
ESP
SPI (Security Parameters Index)
Sequence Number
IP Header
TCP Header
+ Payload
Padding
(variable)
pad len
next=IP
Authentication Data
(optional)
Encrypted
Data
Authenticated
Data


IPSec in AH Transport Mode
Original IPv4 Datagram
IP Header
ver
hlen
TOS
pkt len
ID
flgs
frag offset
TTL
proto=TCP
header cksum
src IP address
dst IP address
TCP Header + payload
TCP header (proto = 6)
TCP payload
Protected by
AH Auth Data
New IP
type
New IPv4 Datagram
IP Header
ver
hlen
TOS
pkt len + AH size
ID
flgs
frag offset
TTL
proto=AH
header cksum
src IP address
dst IP address
AH Header
next=TCP
AH len
Reserved
SPI (Security Parameters Index)
Sequence Number
Authentication Data
(usually MD5 or SHA-1 hash)
TCP Header + payload
TCP header (proto = 6)
TCP payload


IPSec in AH Tunnel Mode
Original IPv4 Datagram
IP Header
ver
hlen
TOS
pkt len
ID
flgs
frag offset
TTL
proto=TCP
header cksum
src IP address
dst IP address
TCP Header + payload
TCP header (proto = 6)
TCP payload
New IP type
New IPv4 Datagram
IP Header
ver
hlen
TOS
pkt len + AH + IP
ID
flgs
frag offset
TTL
proto=AH
header cksum
src IP address
dst IP address
AH Header
next=IP
AH len
Reserved
SPI (Security Parameters Index)
Sequence Number
Authentication Data
(usually MD5 or SHA-1 hash)
Original IP Header
ver
hlen
TOS
pkt len
ID
flgs
frag offset
TTL
proto=TCP
header cksum
src IP address
dst IP address
TCP header (proto = 6)
TCP payload
Protected by
AH Auth Data

2.4 Протокол IKE v2 (RFC 4306)

ISAKMP (Internet Secure Access Key Manage Protocol) – схема (узагальнений протокол) автентифікації сторін з”єднання, узгодження атрибутів захисту та керування ключами.
Oakley (RFC 2412) –створення ключів (гібрид протоколу Діффі - Геллмана захищеного обміну ключами)
SKEME – універсальний механізм захищеного обміну ключами в Internet (механізм застосування відкритих ключів для автентифікації)

Асоціація захису (Security Association, SA) – набір узгоджених параметрів захищеного з”єднання. Структура даних, що описує параметри захисту
(Src IP, Dst IP, SEQ#, Anty-reply window, Lifetime, Mode, AH auth, ESP auth, ESP encr, MTU)

SADB (SA Data Base) – база даних асоціацій захисту (параметрів усіх захищених з”єднань)

PFS (Perfect Forward Secrecy) – нові асоціації захисту параметрично не залежні від попередніх (періодичне повторення обміну Діффі – Геллмана)

Основний режим

Встановлення захищеного каналу, автентифікація сторін (узгодження поділюваного ключа) та автентифікація по захищеному каналу -> встановлення двосторонньої SA

- MM1, MM2 – обмін політиками ISAKMP (параметрами захисту)
- MM3, MM4 – обмін DH
- MM5, MM6 – автентифікація по захищеному каналу

Агресивний режим – передається 3 повідомлення.
Ідентифікатори суб”єктів передаються у відкритому вигляді.

Швидкий режим

Узгодження параметрів IPSec тунеля, автентифікація сторін, встановлення захищеного тунелю –> дві односторонніх SA (ESP и AH окремо).

- QM1, QM2 – узгодження параметрів IPSec
- QM3 – валідація канала до передавання IPSec трафіка (захист від атаки відтворення (Reply))

2.5 Послідовність встановлення IPSec з'єднання

1. Поява трафіку, що вимагає захисту (interesting traffic) ініціює створення IPSec тунелю (Селектор трафіку (ACL) визначає трафік, що буде захищатись)

2. IKE фаза 1 (основний режим) – сторони узгоджують параметри захисту, автентифікуються та встановлюють захищений тунель

3. IKE фаза 2 (швидкий режим) – сторони узгоджують набір перетворень IPSec та встановлюють IPSec тунель

Пакет видаляється приймаючою стороною при:

- Відсутності SA
- Помилці автентифікації
- Номер послідовності поза межами вікна (anty-reply перевірка)
- Не коректна довжина пакета
- Час життя SA закінчився

4. IPSec тунель видаляється або при видаленні IPSec SA або після закінчення часу життя

2.6 Проблеми з впровадженням IP Security (IPSec Challenges)

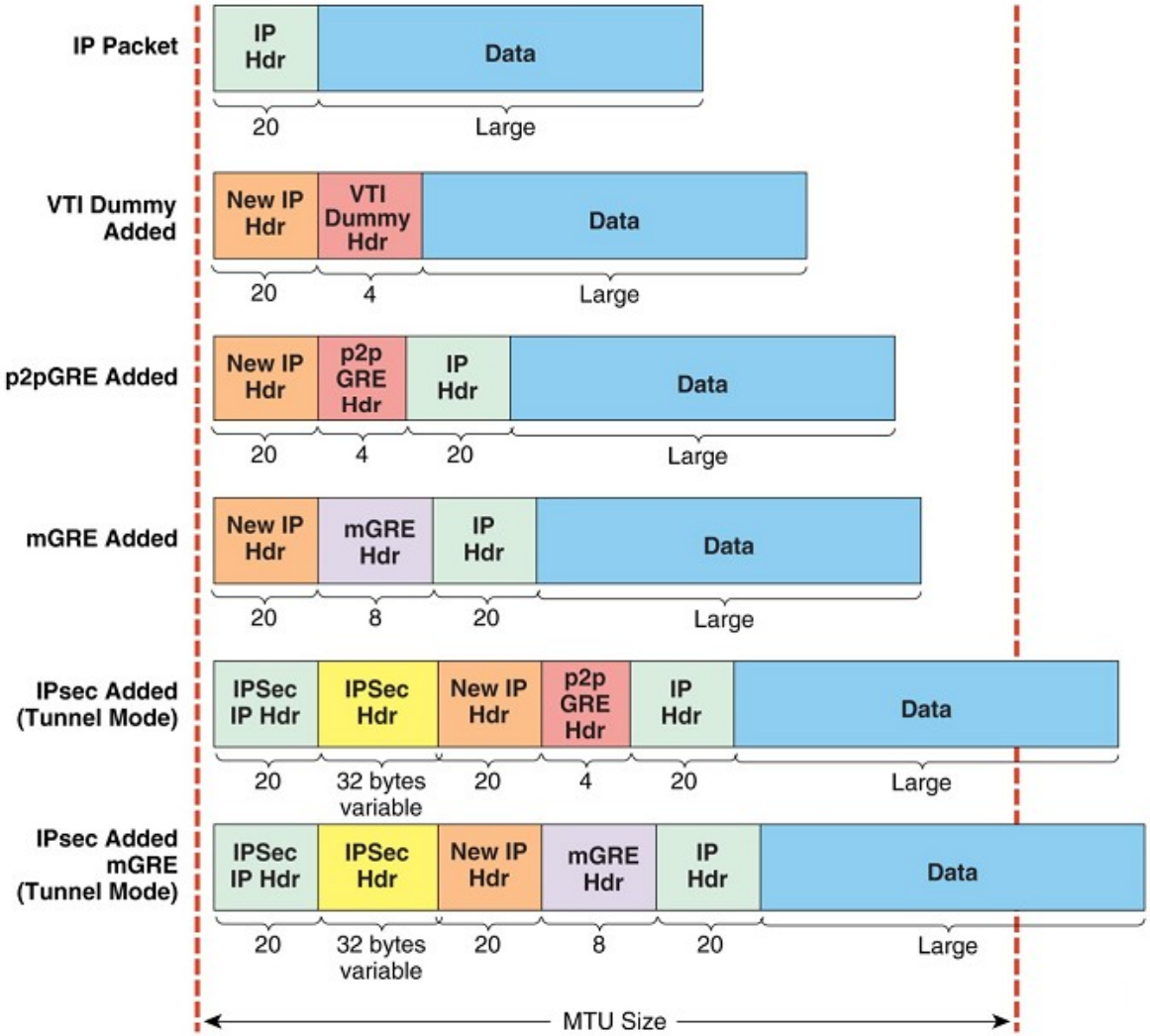
NAT/PAT – порушує AH заголовок
Рішення: IPSec NAT transparency (NAT-T)
(Виявлення NAT та інкапсуляція ESP-трафіка як UDP/4500)

- **Multicast** та **Non-IP** пакети не можут передаватись через IPSec
  Рішення: тунелювання + захист GRE - тунеля

- Тунелювання **multicast** трафіка в IPSec відсутніє (потрібно протоколам маршрутизації)
  Рішення: GET VPN (Group Encrypted Transport)

- Проблеми з **failover** (синхронізація станів) при резервуванні VPN – шлюза

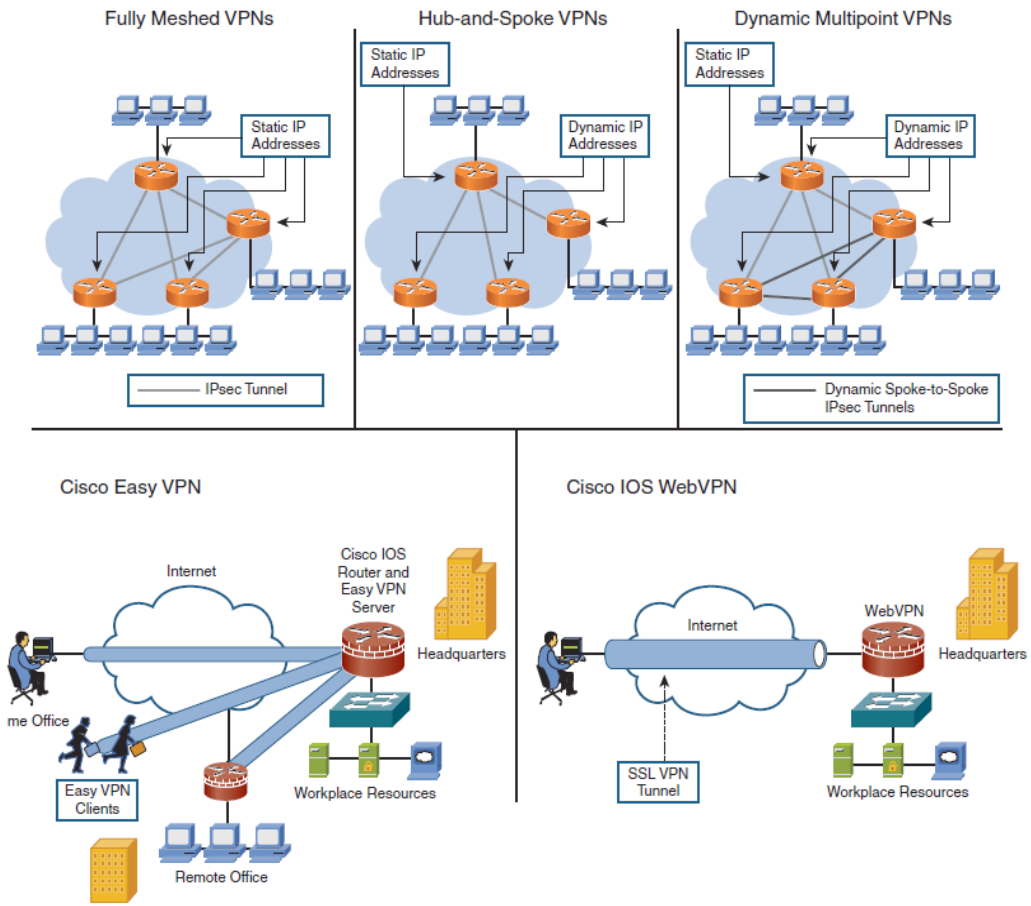
- **Path MTU**



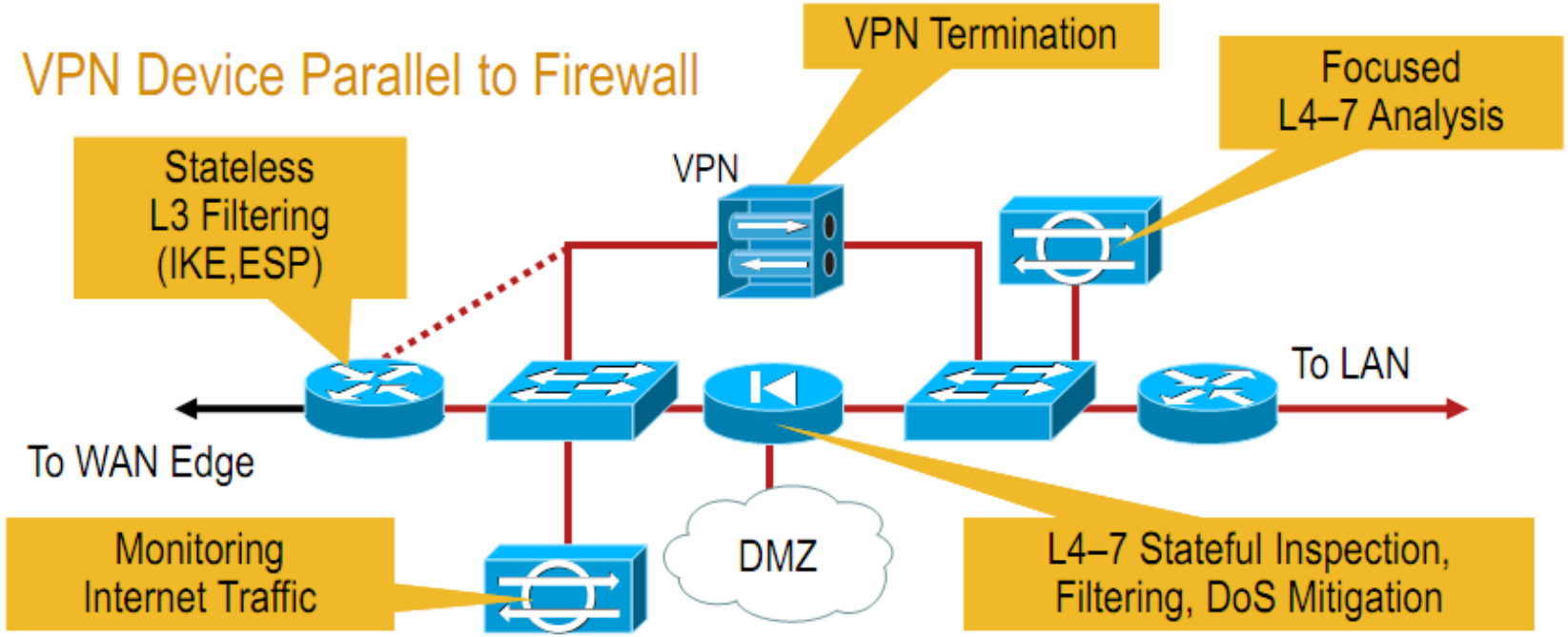
При додаванні додаткових заголовків сумарний розмір пакету може стати більший за MTU деякої проміжної мережі що неминуче викличе фрагментацію і, можливо, порушення цілісності пакетів.
Рішення: підлаштування TCP MSS, встановлення біта DF, фрагментація до застосування IPSec

2.7 Топології IPSec VPN:

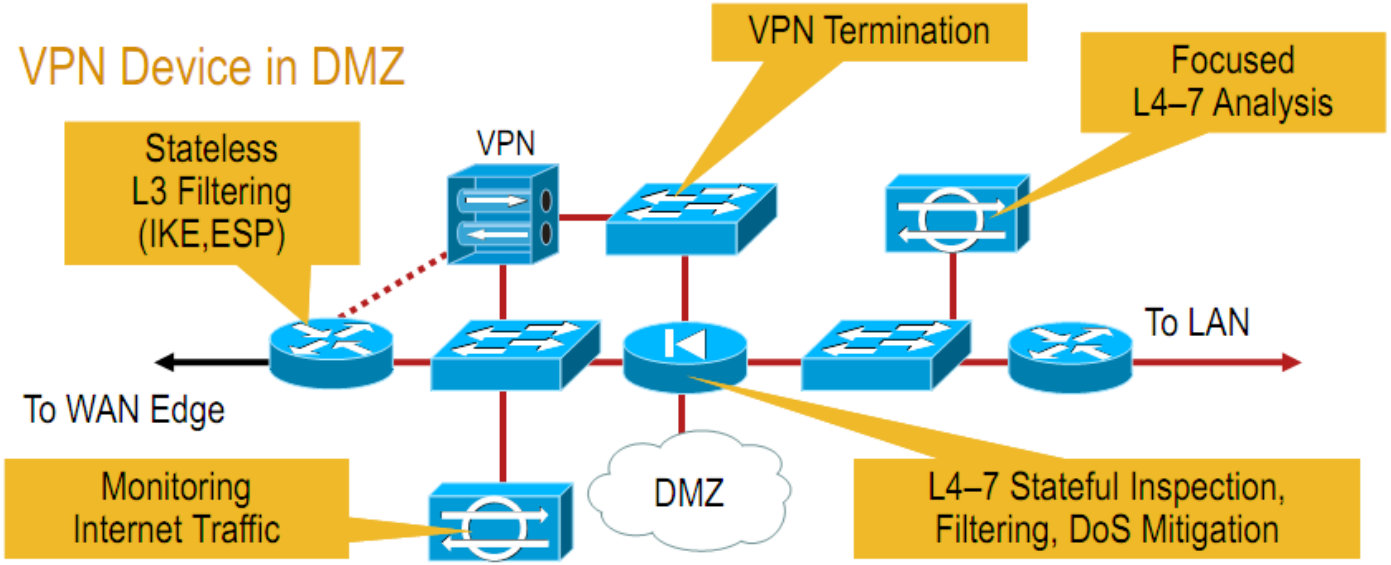
- двоточкова
- повнозв’язна
- hub-and-spoke
- Dynamic multipoint VPN (DMVPN) – CISCO
- Remote Access VPN



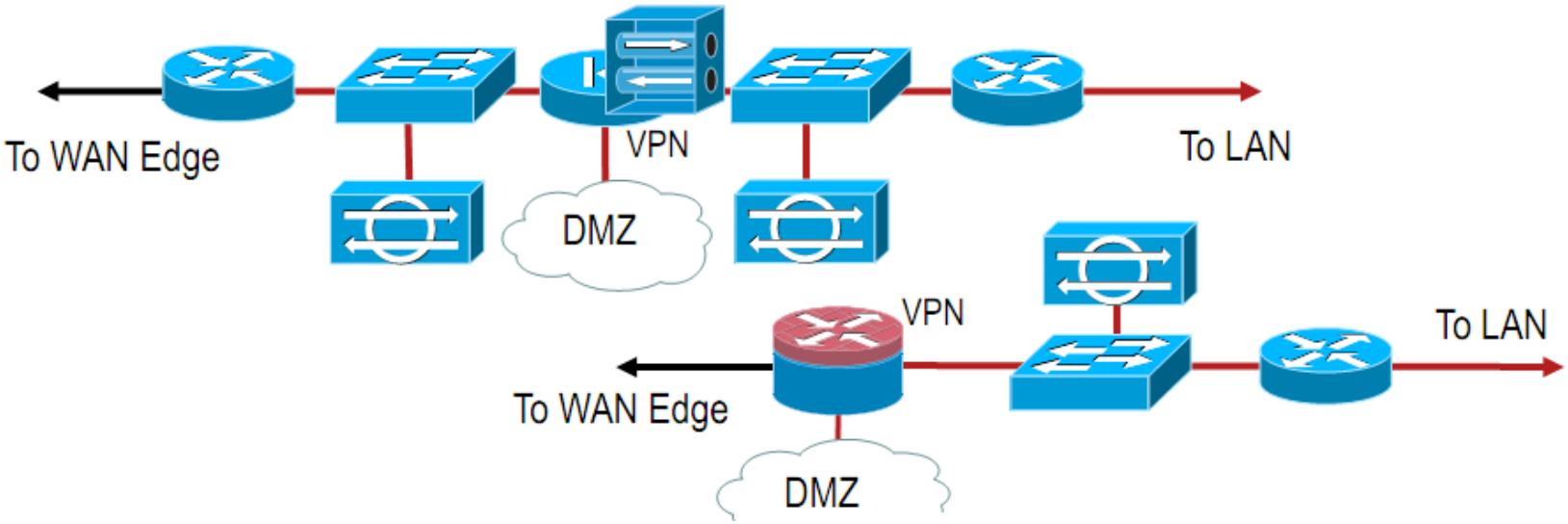
2.8 Розташування пристроїв з IPSec



VPN Device in DMZ



VPN Device: Integrated with Router/Firewall/IDS

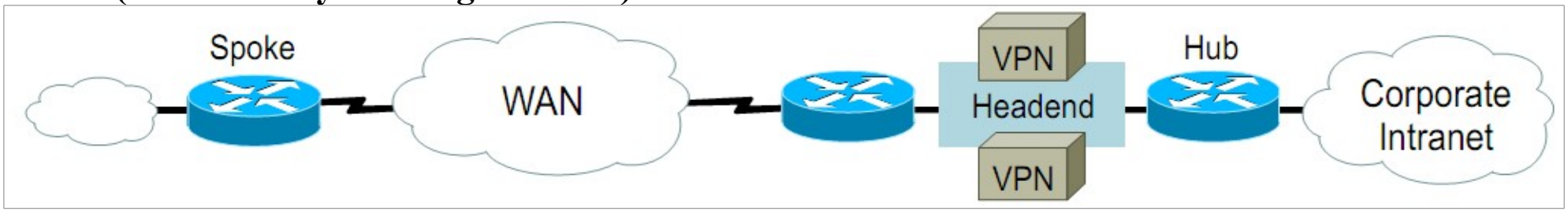


2.9 Відмовостійкість IP Sec VPN

- IKE Keepalive, IPSec SA Idle Timeout – досяжність сторін VPN
- IKE Dead Peer Detection – наявність трафіку підтверджує досяжність
- GRE Tunnel Keepalive – досяжність GRE тунелю
- Dynamic Routing Protocol – досяжність IP адреси

Досяжність IPSec-peer не означає досяжність кінцевих мереж.
Прив'язка тунелів до адрес віртуальних Loopback інтерфейсів дозволяє використовувати кілька фізичних IP адрес.

HSRP (Hot-Standby Routing Protocol)



(відмовостійкість без урахування стану з'єднання)

- **SSP /SSO (State Synchronization Protocol / Stateful Switch Over) –** відмовостійкість з урахуванням стану з'єднання: синхронізація ISAKMP/IPSec SA між активним та резервним HSRP маршрутизаторами

2.10 Масштабування IPSec

- Використання інфраструктури відкритих ключів (PKI)

- Використання динамічних криптокарт (не прив'язаних до IP) дозволяє використовувати одну карту (шаблон) для підключення багатьох абонентів
  Динамічні карти не можуть ініціювати з'єднання (тільки вхідні тунелі)

DMVPN (Dynamic Multipoint VPN) – підключення абонентів з динамічними IP адресами

*Середнє навантаження на CPU пристроїв не має перевищувати 50-65%

ДОДАТКИ

Послідовність налаштування IPSec тунеля

1. Налаштування IKE

```
 crypto isakmp policy 10
 encr 3des
 authentication pre-share
 group 5
```

2. Налаштування автентифікації

```
crypto isakmp key cisco address 192.168.23.3
```

3. Налаштування параметрів IPSec (криптоперетворень)

```
crypto ipsec transform-set 50 ah-sha-hmac esp-3des esp-sha-hmac
```

4. Налаштування криптокарти

```
crypto map MYMAP 10 ipsec-isakmp
 set peer 192.168.23.3
 set security-association lifetime seconds 900
 set transform-set 50
 set pfs group5
 match address 101
```

5. Визначення селектора трафіка (ACL)

```
access-list 101 permit ip 172.16.1.0 0.0.0.255 172.16.3.0 0.0.0.255
```

6. Застосування криптокарти до мережного інтерфейса

```
interface Ethernet0/0
  crypto map MYMAP
```

Діагностика несправностей

- *show crypto map* — перегляд налаштованих криптокарт
- *show crypto isakmp {policy | key |sa}* - перевірка налаштувань IKE політик/ключів/SA
- *show crypto ipsec transform-set* – перевірка налаштувань IPSec перетворень
- *show crypto ipsec sa* - перевірка асоціацій захисту IPSec
- *show access-lists* – перевірка списків контролю доступу (селекторів трафіку)
- *debug crypto isakmp* - діагностика IKE
- *debug crypto ipsec* – діагностика IPSec
- *clear crypto sa* – видалення асоціацій захисту

- Перевірити наявність трафіку, що захищається
  Перевірити правила фільтрації (ESP, AH, IKE)
  Перевірити маршрутизацію
- Перевірити IKE SA для цього абонента (стан QM_IDLE - SA встановлено)
  Поділювані ключі повинні співпадати
  Відповідність IKE політик (Несумісні політики; default 65536)
  IP сторін повинні бути вказані правильно
- Перевірити, що IPSec SA встановлено (Inbound and Outbound SPI)
  Відповідність IPSec перетворень
  Відповідність селекторів трафіку (ACL)
- Перевірити, що криптокарту застосовано правильно

Продукти VPN

Linux

IPSec (kernel 2.4, 2.6):

- FreeS/WAN: **KLIPS** (kernel 2.4 IP Security) + **Pluto** (IKE daemon)
- Open SWAN, Strong SWAN
- KAME (Kernel 2.6; ported from xBSD)
- isakmpd daemon (OpenBSD, Linux kernel 2.6)
- IPSec-tools (kernel 2.6): setkey/ip xfrm (kernel utility) + **Racoon** (IKE daemon)

SSL/TLS:

- OpenVPN
- OpenSSL

різновиди PPP:

- Vtun: multiprotocol; Blowfish, MD5 (use openSSL)
- cIPe: IPoverUDP/TCP; Blowfish/IDEA, DiffyHellman/RSA
- tink: IPoverUDP; Blowfish, RSA (use openSSL)

CISCO IPSec

- IOS
- ASA, PIX
- Easy VPN, Easy VPN Remote
- VPN Client
- VPN Concentrator

Питання по темі **«Віртуальні захищені мережі»**:

Призначення та функції віртуальних захищених мереж.
Які послуги можуть забезпечувати віртуальні захищені мережі.
Яким загрозам запобігають VPN.
Види та топології віртуальних захищених мереж.
Які мережні пристрої можуть виконувати роль шлюзу VPN.
Рівні VPN.
Протоколи захисту даних на канальному рівні.
Характеристики протоколу PPTP.
Протоколи TLS/SSL. Призначення та завдання, принцип роботи та характеристики.
Процедура встановлення TLS/SSL з'єднання. Види записів у повідомленнях.
В яких повідомленнях TLS/SSL надсилається цифровий сертифікат.
Які криптографічні алгоритми використовують протоколи TLS/SSL.
Які криптографічні алгоритми застосовують у розглянутому вами прикладі.

Архітектура протоколів IP Security. Призначення та характеристики протоколів IKE, ESP, AH.
Які методи автентифікації застосовуються в технології IPSecurity.
Які криптографічні алгоритми можуть використати протоколи IKE, ESP, AH.
Режими роботи IPSecurity VPN. Їхні особливості.
Послідовність встановлення IPSec з'єднання.
Режими роботи протоколу IKE.
Що таке "Гарантована майбутня безпека" (Perfect Future Secrecy).
Що таке "асоціація захисту". Які параметри вона містить.
Обмеження використання IPSecurity VPN.